

politica-sgsdp-grt

security-system/politica-sgsdp-grt.docx

Objetivo

La presente Política del Sistema de Gestión de Seguridad de Datos Personales (en adelante “Política”) elaborada por Grünenthal de México, S.A. de C.V. (en lo sucesivo “Grünenthal”), tiene el fin de dar cumplimiento a las obligaciones establecidas en la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (en adelante “LFPDPPP”) publicada el 20 de marzo de 2025 en el Diario Oficial de la Federación.

En esta Política, se definen las directrices y principales controles que conforman el Sistema de Gestión de Seguridad de Datos Personales (SGSDP), basado en el ciclo PHVA (Planear, Hacer, Verificar y Actuar), de acuerdo con lo previsto por las RSDP, la GISGSDP y demás lineamientos y criterios de carácter internacional aplicables en materia de seguridad de la información.

Grünenthal reconoce que la información, la privacidad y los datos personales son un activo imprescindible para la organización, por lo que se considera fundamental garantizar su protección, restringiendo su acceso, uso y divulgación mediante la instrumentación de las medidas de seguridad de tipo administrativo, físico y técnico que conforman el SGSDP.

Por lo que, el objetivo de la presente Política es definir las directrices y normas básicas de observancia obligatoria para la correcta implementación de un SGSDP, basado ciclo PHVA para la protección de los datos personales y su tratamiento legítimo, controlado e informado, a efecto de garantizar la privacidad y el derecho a la autodeterminación informativa de los titulares.

Ámbito

La Política y el SGSDP se dirigen a todos los Custodios, Propietarios y Responsables de Activos de Grünenthal conforme a la normatividad vigente en México, sin perjuicio de que voluntariamente, Grünenthal pueda asumir estándares de cumplimiento más exigentes como, por ejemplo, aquellos previstos en directrices y estándares internacionales de seguridad informática.

Objetivos.

Son objetivos específicos de esta Política:

Definir las políticas y controles de seguridad que propicien una adecuada protección de la información de Grünenthal.

Garantizar la confidencialidad de los datos personales e información en posesión de Grünenthal.

Mantener la integridad de los datos personales e información en posesión de Grünenthal de modo que no sufran alteraciones con respecto al momento en que haya sido generada por los propietarios o responsables de la misma.

Asegurar la disponibilidad de la información y datos personales en posesión de Grünenthal en todos los soportes y siempre que sea necesaria, asegurando la continuidad del negocio y el cumplimiento de las obligaciones exigibles a Grünenthal

Identificar políticas, objetivos, riesgos, planes, procesos y procedimientos necesarios para la protección de los datos personales.

Implementar y operar las políticas, objetivos, planes, procesos y procedimientos para la protección de los datos personales.

Evaluar y medir los resultados de las políticas, objetivos, planes, procesos y procedimientos implementados, a fin de verificar el continuo mejoramiento del SGSDP.

Adoptar medidas correctivas y preventivas, en función de los resultados y de la revisión hecha al SGSDP.

Términos y definiciones

Términos

Definición/Explicación

Aviso de Privacidad

Documento a disposición de la persona titular de la información de forma física, electrónica o en cualquier otro formato generado por Grünenthal, a partir del momento en el cual se recaben sus datos personales, con el objeto de informarle los propósitos del tratamiento de los mismos.

Base de datos

Conjunto ordenado de datos personales referentes a una persona identificada o identificable condicionados a criterios determinados, con independencia de la forma o modalidad de su creación, tipo de soporte, procesamiento, almacenamiento y organización.

Consentimiento

Manifestación de la voluntad libre, específica e informada de la persona titular de los datos mediante la cual se efectúa el tratamiento de los mismos.

Datos personales

Cualquier información concerniente a una persona identificada o identificable. Se considera que una persona es identificable cuando su identidad pueda determinarse directa o indirectamente a través de cualquier información

Datos personales sensibles

Aquellos datos personales que afecten a la esfera más íntima de la persona titular, o cuya utilización indebida pueda dar origen a discriminación o conlleve un riesgo grave para esta. De manera enunciativa más no limitativa se consideran sensibles los datos personales que puedan revelar aspectos como origen racial o étnico, estado de

salud presente o futuro, información genética, creencias religiosas, filosóficas y morales, opiniones políticas y preferencia sexual.

Derechos ARCO

Son los derechos de Acceso, Rectificación, Cancelación, Oposición. Adicionalmente, se consideran los derechos de revocación de consentimiento y limitación de uso y/o divulgación de Datos Personales.

Grünenthal Global

Se refiere a la matriz de Grünenthal y las políticas globales que establece como obligatorias para todas sus subsidiarias.

Vulneración de Seguridad

Se refiere a todo incidente que afecte las medidas de seguridad administrativas, técnicas o físicas implementadas por el Responsable y que tenga como consecuencia la destrucción, pérdida, alteración, uso o divulgación no autorizados de datos personales, ya sea de manera accidental o ilícita.

Responsabilidad

En esta sección se proporciona información sobre las funciones implicadas en el proceso descrito.

Principios generales de la SGSDP

La consecución de los objetivos del SGSDP se articula a través de los siguientes principios generales:

5.1. Clasificación de información.

La información se clasificará en función a su valor, importancia y criticidad para el negocio, de forma que las medidas de protección se puedan adecuar al nivel de clasificación de cada activo de información. Del mismo modo, la clasificación de los activos de información se realizará tomando en consideración los requisitos legales, operacionales, las buenas prácticas y estándares relacionados.

Uso de los Sistemas de Información.

El uso de los Sistemas está limitado a fines lícitos y exclusivamente profesionales. Es decir, se deberán utilizar estrictamente para la realización de tareas relacionadas con el puesto de trabajo. En consecuencia, los medios y sistemas no están destinados para el uso personal ni para utilizarse para ninguna finalidad ilícita.

Segregación de Funciones.

Se deberán evitar las concentraciones de riesgos derivados de la ausencia de segregación de funciones y la dependencia unipersonal de funciones críticas para el negocio. Se deberán establecer procedimientos formales para controlar la asignación de privilegios a los Sistemas de Información, de forma que los usuarios tengan acceso únicamente a los recursos e información necesarios para el desempeño de sus funciones.

Retención de la Información.

Se establecerán, cuando resulte necesario o conveniente, periodos de retención de la información por categorías atendiendo a las necesidades operativas o de cumplimiento regulatorio, así como procedimientos de destrucción de la Información.

Acceso a la Información por parte de Terceros.

Se desarrollarán los procedimientos de control de la puesta a disposición y acceso por terceros a la información relativa a Grünenthal o de cualesquiera otros terceros relacionados con Grünenthal.

Seguridad de la Información en los Sistemas.

Los entornos de desarrollo y producción se mantendrán en Sistemas independientes. Igualmente, el desarrollo y mantenimiento de los Sistemas de Información deben incluir los controles y registros necesarios para garantizar la correcta implementación de las especificaciones de seguridad

Continuidad.

Se establecerá un proceso de gestión de continuidad que permita garantizar crítica para Grünenthal en caso de desastre, reduciendo el tiempo de indisponibilidad a niveles aceptables.

Cumplimiento.

Los Sistemas de Información y comunicaciones de Grünenthal estarán adecuados de forma permanente según las exigencias de la legislación así como a la normativa interna de desarrollo.

Sistemas de Gestión de Seguridad de Datos Personajes

El Sistema de Gestión de Seguridad de Datos Personales (en adelante, “SGSDP”) se basa en el modelo denominado “Planificar-Hacer-Verificar-Actuar” (PHVA), a través del cual se dirigen y controlan los procesos o tareas de acuerdo con la siguiente tabla.

Sistema de Gestión

Proceso

Elemento del SG

Fases del PHVA

Actividades

Metas

Planificar

Se identifican objetivos, riesgos, planes, procesos y procedimientos necesarios para obtener el resultado esperado por la organización (meta).

Medios de acción

Hacer

Se implementan y operan los objetivos, planes, procesos y procedimientos establecidos en la fase anterior.

Verificar

Se evalúan y miden los resultados de los objetivos, planes, procesos y procedimientos implementados, a fin de verificar que se haya logrado la mejora esperada.

Actuar

Se adoptan medidas correctivas y preventivas, en función de los resultados y de la revisión, o de otras informaciones relevantes, para lograr la mejora continua.

Implementación del SGSDP

La implementación del SGSDP en Grünenthal se llevará a cabo en las siguientes fases:

Planear el SGSDP.

Implementar y operar el SGSDP.

Monitorear y revisar el SGSDP.

Mejorar el SGSDP.

7.1. Planeación del SGSDP

En esta fase del SGSDP, Grünenthal identificará los objetivos, riesgos, planes, procesos y procedimientos necesarios para garantizar la seguridad de los datos personales.

Política General de Protección de Datos Personales.

De acuerdo con los alcances y objetivos definidos en esta Política, se ha implementado una Política General de Datos Personales para el cumplimiento de los objetivos descritos en el SGSDP.

La Política General de Protección de Datos Personales (en adelante “Política General”) de Grünenthal fue generada tomando en consideración las obligaciones legales de Grünenthal en materia de datos personales, las mejores prácticas en la materia y de acuerdo con las Políticas Globales de Grünenthal para todas las empresas pertenecientes al mismo grupo comercial.

La Política General desarrolla las siguientes reglas:

El cumplimiento de todos los principios que establece la LFPDPPP: licitud, consentimiento, información, calidad, finalidad, lealtad, proporcionalidad y responsabilidad, conforme a lo que señala la propia Ley y demás normativa aplicable;

Tratar y recabar datos personales de manera lícita, conforme a las disposiciones establecidas por la Ley y demás normativa aplicable (principio de licitud);

Sujetar el tratamiento de datos personales al consentimiento del titular, salvo las excepciones previstas por la Ley (principio de consentimiento);

Informar a los titulares de los datos, la información que se recaba de ellos y con qué fines, a través del aviso de privacidad (principio de información);

Procurar que los datos personales tratados sean correctos y actualizados (principio de calidad);

Suprimir los datos personales cuando hayan dejado de ser necesarios para el cumplimiento de las finalidades previstas en el aviso de privacidad y para las cuales se obtuvieron (principio de calidad);

Tratar datos personales estrictamente el tiempo necesario para propósitos legales, regulatorios o legítimos organizacionales (principio de calidad);

Limitar el tratamiento de los datos personales al cumplimiento de las finalidades previstas en el aviso de privacidad (principio de finalidad);

No obtener los datos personales a través de medios fraudulentos (principio de lealtad);

Respetar la expectativa razonable de privacidad del titular (principio de lealtad);

Tratar los menos datos personales posibles, y sólo aquéllos que resulten necesarios, adecuados y relevantes en

relación con las finalidades previstas en el aviso de privacidad (principio de proporcionalidad);

Velar por el cumplimiento de estos principios y adoptar las medidas necesarias para su aplicación (principio de responsabilidad);

Establecer y mantener medidas de seguridad (deber de seguridad);

Guardar la confidencialidad de los datos personales (deber de confidencialidad);

Identificar el flujo y ciclo de vida de los datos personales: por qué medio se recaban, en qué procesos de Grünenthal se utilizan, con quién se comparten, y en qué momento y por qué medios se suprimen;

Mantener un inventario o registro interno de datos personales actualizado de los datos personales o de sus categorías que maneja Grünenthal;

Respetar los derechos de los titulares en relación con sus datos personales;

Aplicar las excepciones contempladas en la normativa en materia de protección de datos personales;

Desarrollar e implementar el SGSDP de acuerdo con la política de gestión de datos personales, y

Definir las partes interesadas y miembros de Grünenthal con responsabilidades específicas y a cargo de la rendición de cuentas para el SGSDP.

Establecimiento de funciones y obligaciones de quienes tratan los datos personales.

La determinación de las funciones y obligaciones del personal que trate datos personales implica la obligación de identificar los roles relevantes en el tratamiento de datos personales en el interior de Grünenthal y establecer las obligaciones de los actores significativos en relación con el tratamiento de los datos personales.

Los roles y obligaciones que pueden tener los diferentes actores dentro de Grünenthal están definidos en la política global de Grünenthal en la materia. Por lo cual es importante conocer dicha política.

Registro 2B Advice PRIME e inventario de datos personales.

Grünenthal debe contar con un mecanismo que permita registrar los tratamientos de datos personales y las categorías de datos personales tratados, de conformidad con su política global en materia de protección de datos personales. En ese sentido, el medio definido por Grünenthal Global para cumplir con dicha obligación es el

registro identificado como 2B Advice PrIME.

Como buena práctica adicional y de manera complementaria a dicho registro, Grünenthal llevará un Inventario de Datos Personales, el cual funciona como un registro personalizado, creado específicamente para México, de conformidad con lo previsto en la normativa aplicable en materia de protección de datos personales. Este inventario tiene por objeto identificar los tratamientos realizados y su ciclo de vida y como estos tratamientos cumplen con los requerimientos establecidos por la LFPDPPP.

El ciclo de vida de los datos personales que se reflejará en el Inventario de Datos Personales considerará, al menos, los siguientes elementos:

Es decir, conforme a los criterios anteriores, el Inventario de Datos Personales, además de permitir a Grünenthal conocer los datos sujetos a tratamiento, le hará posible definir la relación que el personal guarda con el tratamiento de datos personales.

A partir del ciclo de vida del dato, se podrá identificar qué tipo de tratamiento efectúa cada uno de ellos, así como el grado de responsabilidad, de modo que a través de un registro documentado se puedan conocer los privilegios y límites que tiene cada individuo.

De forma enunciativa, pero no limitativa, el Inventario de Datos Personales podrá considerar las siguientes categorías de datos personales y sistemas de tratamiento:

NIVELES DE SEGURIDAD

Nivel estándar

Nivel sensible

Nivel especial

Esta categoría considera información de identificación, contacto, datos laborales y académicos de una persona física identificada o identificable, tal como: nombre, teléfono, edad, sexo, RFC, CURP, estado civil, dirección de correo electrónico, lugar y fecha de nacimiento, nacionalidad, puesto de trabajo, lugar de trabajo, experiencia

laboral, datos de contacto laborales, idioma o lengua, escolaridad, trayectoria educativa, títulos, certificados, cédula profesional, entre otros.

Esta categoría contempla los datos que permiten conocer la ubicación física de la persona, tales como la dirección física e información relativa al tránsito de las personas dentro y fuera del país.

Datos patrimoniales

También son datos de nivel sensible aquéllos que permitan inferir el patrimonio de una persona, que incluye entre otros, los saldos bancarios, estados y/o número de cuenta, cuentas de inversión, bienes muebles e inmuebles, información fiscal, historial crediticio, ingresos, egresos, buró de crédito, seguros, afores y fianzas. Incluye el número de tarjeta bancaria de crédito y/o débito.

Datos de autenticación

Son considerados también los datos de autenticación con información referente a los usuarios, contraseñas, información biométrica (huellas dactilares, iris, voz, entre otros), firma autógrafa y electrónica y cualquier otro que permita autenticar a una persona.

Dentro de esta categoría se toman en cuenta los datos jurídicos tales como antecedentes penales, amparos, demandas, contratos, litigios y cualquier otro tipo de información relativa a una persona que se encuentre sujeta a un procedimiento administrativo seguido en forma de juicio o jurisdiccional en materia laboral, civil, penal o administrativa.

Datos sensibles según la LFPDPP1

Finalmente, se contemplan los datos personales sensibles de la Ley, es decir, aquéllos que afecten a la esfera más íntima de su titular. Por ejemplo, se consideran sensibles los que puedan revelar aspectos como origen racial o étnico, estado de salud pasado, presente y futuro, información genética, creencias religiosas, filosóficas y morales, afiliación sindical, opiniones políticas, preferencia sexual, hábitos sexuales y cualquier otro cuya utilización indebida pueda dar origen a discriminación o conlleve un riesgo grave a la integridad del titular.

Los datos de nivel especial son los que de acuerdo a su naturaleza y contexto pueden causar un daño excepcional a los titulares, por ejemplo:

Información adicional de tarjeta de crédito

Información adicional de tarjeta bancaria que considera el número de la tarjeta de crédito y/o débito mencionado

anteriormente en combinación con cualquier otro dato relacionado o contenido en la misma, por ejemplo, fecha de vencimiento, códigos de seguridad, datos de banda magnética o número de identificación personal (PIN).

Datos personales de titulares de alto riesgo

Los datos personales de titulares de alto riesgo, cuya profesión, oficio o condición los expone a una mayor probabilidad de ser atacados debido al beneficio económico o reputacional que su información representa para una persona no autorizada. Por ejemplo, líderes políticos, religiosos, empresariales, de opinión y cualquier otra persona que sea considerada como personaje público.

Impartición de justicia y seguridad nacional

Asimismo, se considera a cualquier persona cuya profesión esté relacionada con la impartición de justicia y seguridad nacional.

Grünenthal mantendrá actualizado el Inventario de Datos Personales a través de las plataformas y/o mecanismos que el Departamento de Datos Personales habilite para dicho registro.

Evaluación de Impacto de la Protección de Datos Personales y Análisis de Riesgo.

Evaluación de Impacto de la Protección de Datos

De conformidad con las políticas globales en materia de protección de datos personales de Grünenthal Global, Grünenthal tiene la obligación de realizar una Evaluación de Impacto a la Protección de Datos Personales cuando el tratamiento de datos personales pueda implicar un alto riesgo para los derechos y libertades de los titulares.

La Evaluación de Impacto tiene por objeto identificar los riesgos inherentes al tratamiento de los datos personales y, con base en dicho análisis, definir las medidas de seguridad y mitigación necesarias para salvaguardar los derechos de los titulares y asegurar un tratamiento adecuado.

La metodología y los criterios que Grünenthal debe implementar para la elaboración de estas evaluaciones se encuentran establecidos en la Política para la Elaboración de Evaluaciones de Impacto a la Protección de Datos Personales de Grünenthal.

Análisis de riesgo

Además de la Evaluación de Impacto a la Protección de Datos Personales, Grünenthal establecerá la

implementación de un Análisis de Riesgo, como un proceso complementario a dicha evaluación. A diferencia de la Evaluación de Impacto, el Análisis de Riesgo tiene un enfoque más específico y contextualizado al entorno regional, y se basa en la Metodología de Análisis de Riesgo BAA, publicada por el INAI, autoridad que ejercía las funciones de protección de datos personales en México.

La metodología referida considera tres variables que influyen en la percepción del valor de los datos personales para un posible atacante:

Beneficio para el atacante. Aquellos datos personales que representen mayor beneficio tienen más probabilidad de ser atacados (por ejemplo, beneficio económico por venderlos o usarlos).

Accesibilidad para el atacante. Aquellos datos personales que sean de fácil acceso tienen mayor probabilidad de ser atacados (por ejemplo, miles de personas pueden acceder a la vez a una base de datos a través de un sitio web, pero sólo unas cuantas lo podrían hacer a un archivero).

Anonimidad del atacante. Aquellos datos personales cuyo acceso represente mayor anonimidad tienen más probabilidad de ser atacados (por ejemplo, internet es un medio más anónimo que presentarse físicamente a las instalaciones de una empresa).

El objetivo final de esta metodología es determinar los controles recomendados de protección de datos de acuerdo con el entorno de riesgo existente. Por lo tanto, estas listas de controles se identificarán al final, utilizando tres factores:

Riesgo por tipo de dato (beneficio);

Nivel de accesibilidad, y

Nivel de anonimidad.

De acuerdo con la GISGSDP la determinación del riesgo en Grünenthal considerará los siguientes elementos:

Acciones para la determinación del riesgo

Acción

Descripción

Aspectos para considerar

Valoración Respecto al Riesgo

La valoración del riesgo identifica los activos existentes, las amenazas aplicables, y los escenarios de vulneración.

La valoración del riesgo debe considerar:

- El establecimiento y mantenimiento de criterios de aceptación de riesgos.

- La determinación de los criterios para evaluar los riesgos.

- Asegurar que las diferentes evaluaciones del riesgo generen resultados consistentes

válidos y comparables.

Identificar Activos

En términos del SGSDP estos activos deberán ser aquéllos que estén relacionados con el ciclo de vida de los datos personales previamente identificado y sus distintos tratamientos. Los activos se deben identificar y ponderar con suficiente nivel de detalle para proveer información que permita hacer la valoración del riesgo.

-Los activos se deben identificar y ponderar con suficiente nivel de detalle para proveer información que permita hacer la valoración del riesgo.

Se pueden identificar dos tipos de activos: los activos de información y los activos de apoyo.

Después de identificar y describir los activos de información y de apoyo, se podrán encontrar sus vulnerabilidades y posibles amenazas.

-Se debe definir al custodio del activo.

Identificar amenazas

Una amenaza es una circunstancia que tiene el potencial de dañar un activo y causar una vulneración a la seguridad.

- Las amenazas pueden ser de origen natural o humano, y pueden ser accidentales o deliberadas y además provenir de adentro o desde afuera de la organización.

-Las amenazas deben ser identificadas considerando que algunas pueden afectar a más de un activo al mismo tiempo.

Identificar vulnerabilidades

Una vulnerabilidad es una falta o debilidad de seguridad en un activo o grupo de activos que puede ser explotada por una o más amenazas.

Las vulnerabilidades pueden ser identificadas en los siguientes ámbitos: organizacionales, de procesos y procedimientos, de personal, del ambiente físico, de la configuración de sistemas de información, del hardware, software o equipo de comunicación, de la relación con prestadores de servicios y de la relación con terceros

Identificar Escenarios de Vulneración y Consecuencias

Se deben identificar las consecuencias de las posibles vulneraciones.

La organización debe identificar las consecuencias de una posible vulneración considerando los criterios para la evaluación del riesgo establecidos previamente, de forma que pueda priorizar los riesgos identificados.

El análisis de riesgo establecerá como resultado un valor del riesgo para cada uno de los activos identificados con respecto a los supuestos que pudieran involucrar una vulneración de seguridad.

Como medidas de control para atender el riesgo, Grünenthal podrá considerar las siguientes medidas de control:

Tipología de riesgo

Riesgo

Medidas de control

Integridad de los datos personales

Modificación o alteración de datos personales

Segregación de funciones mediante perfiles de acceso.

Controles de monitorización de amenazas en red.

Disponibilidad de los datos personales

Pérdida o borrado no intencionado de datos personales

Copias de seguridad.

Almacenamiento en dos ubicaciones diferentes.

Confidencialidad de los datos personales

Acceso no autorizado a los datos personales

Mecanismos de control de acceso.

Segmentación de la red.

Garantizar el ejercicio de los derechos de los titulares

Ausencia de procedimientos para el ejercicio de derechos

Procedimientos y canales para el ejercicio de derechos.

Garantizar los principios de protección de datos

Ausencia de legitimidad para el tratamiento de los datos personales.

Cláusulas informativas y base legítima para el tratamiento de datos.

Tratamiento ilícito de datos personales

Monitorización del uso de los datos personales.

IDENTIFICACIÓN DE LAS MEDIDAS DE SEGURIDAD Y ANÁLISIS DE BRECHA

Identificación de medidas de seguridad

Grünenthal establecerá las medidas de seguridad que correspondan a los tratamientos de datos personales

realizados en la organización, considerando diversos factores, tales como el riesgo inherente por tipo de dato personal, la sensibilidad de los datos, el desarrollo tecnológico, las posibles consecuencias de una vulneración para los titulares, el número de titulares, las vulneraciones previas ocurridas, así como el riesgo derivado del valor potencial, cuantitativo o cualitativo, que los datos personales tratados pudieran representar para un tercero no autorizado, entre otros factores que puedan incidir en el nivel de riesgo o que resulten de otras leyes o regulación aplicable.

Los controles y medidas de seguridad administrativas, físicas y técnicas implementados en Grünenthal se agrupan en los siguientes diez dominios principales:

Dominio

Control

1. Políticas del SGSDP

Políticas de gestión de datos personales.

Revisión y evaluación de las Políticas del SGSDP.

Documentación del SGSDP.

2. Cumplimiento legal

Identificación de legislación/regulación aplicable.

Salvaguarda de registros organizacionales

Prevención del mal uso de activos

Recolección de evidencia

Revisión de cumplimiento técnico

Controles de auditoría de sistema

3. Estructura organizacional de la seguridad.

Protección del soporte de auditoría del sistema.

Administración y Coordinación de la seguridad de la información

Designación de deberes en seguridad y protección de datos personales

Recomendaciones de un especialista en seguridad de la información

Cooperación con organizaciones

Revisión de implementación

Identificación de riesgos de terceros

Requerimientos de seguridad en contratos con terceros

Requerimientos de seguridad en contratos con servicios de almacenamiento de información y computo en la nube

4. Clasificación y acceso a los activos

Inventario y clasificación de datos personales

Inventario de activos

Identificación de procesos de datos personales

5. Seguridad del personal

Identificar responsabilidades de seguridad en cada puesto de trabajo

Revisión de contratación del personal

Acuerdos de confidencialidad

Términos y condiciones de empleo

Entrenamiento y educación

Proceso disciplinario

6. Seguridad física y ambiental

Perímetro de seguridad

Control de entrada física

Seguridad en entornos de trabajo

Trabajo en áreas restringidas

Seguridad del cableado

Mantenimiento del equipo

Aseguramiento de los activos fuera de las instalaciones

Borrado seguro de información

Escritorio limpio

Robo de propiedad

7. Gestión de comunicaciones y operaciones

Control de cambios operacionales

Segregación de tareas

Separación del área de desarrollo de sistemas de datos personales

Administración externa de instalaciones

Estándares de configuración segura y actualización de sistemas

Protección contra software malicioso

Respaldo de la información

Registros de operadores

Registro de fallas

Controles de red

Gestión de soportes informáticos extraíbles

Documentación de seguridad del sistema

Seguridad de medios en tránsito

Comercio electrónico seguro

Mensajería electrónica

Seguridad en sistemas electrónicos

Divulgación de información de manera pública

Otras formas de intercambio de información

Disociación y Separación

8. Control de acceso

Reglas de control de acceso

Gestión de usuarios y contraseñas

Gestión de privilegios

Revisión de privilegios de usuarios

Equipos sin atender

Uso de servicios de red

Ruta reforzada

Autenticación de usuario para conexiones externas

Autenticación de nodo

Segregación de redes

Protocolos de conexión de red

Protocolos de enrutamiento

Seguridad de servicios de red

Identificación automática de terminales

Proceso de inicio de sesión

Alerta de coerción a usuarios

Tiempo límite de terminal

Tiempo límite de conexión

Restricción de acceso a datos personales

Trazabilidad de tratamiento

Aislamiento de sistemas sensibles

Registro de eventos

Monitorear el uso del sistema

Sincronización de relojes

Dispositivos móviles internos

Dispositivos móviles externos.

Almacenamiento privado dentro del entorno de operación

Teletrabajo

9. Desarrollo y mantenimiento de sistemas

Validación de datos de entrada

Autenticación de mensajes

Validación de datos de salida

Cifrado

Firmas electrónicas

Servicios de no- repudio

Control de software y sistemas

Protección de datos de prueba del sistema

Control de acceso a software de configuración

Canales encubiertos y código malicioso

Contratación de servicios de software

10. Vulneraciones del sistema

Procedimientos para el manejo de incidentes

Procedimientos de acción en caso de incidente

Reporte de incidentes de seguridad

Reporte de fallas en funcionamiento

Procedimientos de notificación de vulneraciones de seguridad a titulares

Aprendizaje de incidentes

Procedimientos de actualización de SGSDP

Análisis de Brecha

Grünenthal realizará un Análisis de Brecha en virtud del cual identificará los siguientes elementos:

Las medidas de seguridad existentes y efectivas.

Las medidas de seguridad faltantes.

La existencia de nuevas medidas de seguridad que pudieran reemplazar uno o más controles implementados actualmente.

Es importante tener claro cuáles son los controles que ya están funcionando en una organización de manera efectiva, con su respectivo nivel de madurez, así como las medidas identificadas para desarrollar un programa de trabajo que refleje los recursos designados, los responsables, y las fechas compromiso para su implementación. De manera que se pueda medir la eficacia del SGSDP con respecto de los riesgos tratados.

La madurez de los controles identificados en el Análisis de Brecha se identificará de acuerdo con los siguientes niveles:

Documentado. Se ha plasmado en un documento las características y objetivos del control, así como las medidas que soportan su cumplimiento.

Implementado. El control ya se encuentra puesto en marcha a través de una o más medidas de seguridad.

Registros. Se generan registros de la operación del control y de sus medidas de seguridad.

Monitoreo. Se han establecido métricas que permiten dar seguimiento a la eficacia del control.

Indicadores Clave de Rendimiento (Key Performance Indicators, KPI) e Informes. Se han identificado las métricas más significativas y son reportadas a las Partes Interesadas para la toma de decisiones.

Mejora continua. Se toman las acciones necesarias para incrementar la eficacia de los controles con respecto al

monitoreo realizado.

Automatizado. El control requiere poca o nula interacción de una persona, en su operación, monitoreo o ajustes.

El proceso de Análisis de Brecha será debidamente documentado por Grünenthal mediante la Política y el Proceso correspondiente.

Implementación y operación del SGSDP.

En esta fase, Grünenthal documentará el proceso de implementación y operación de lineamientos, procesos, procedimientos y controles o mecanismos del SGSDP. En esta fase, también se implementan las medidas de seguridad resultantes del análisis de riesgos realizado en la fase de planeación anterior.

Implementación de las medidas de seguridad.

Cumplimiento cotidiano de las medidas de seguridad.

En Grünenthal se consideran un conjunto de indicadores para identificar de manera oportuna, cualquier cambio en el contexto de los Tratamientos presentes en Grünenthal y así mantener una visión general de la imagen del riesgo con la intención de adoptar decisiones más efectivas para proteger los datos personales.

En Grünenthal la naturaleza de los indicadores se establece en función del tipo de Activo y su constante monitoreo de conlleva una detección temprana de posibles amenazas para lograr una respuesta a incidentes efectiva.

Rol del Departamento de Datos Personales.

En el interior de Grünenthal se ha designado al Departamento de Datos Personales como el área responsable de la rendición de cuentas en materia de gestión de datos personales dentro de la organización, de forma que tanto el cumplimiento de la legislación aplicable en protección de datos personales, como la observancia de la política de gestión y seguridad de datos personales, puedan ser debidamente demostrados.

Para efectos de la protección de datos personales el Departamento de Datos Personales de Grünenthal tiene a su cargo el cumplimiento cotidiano de los lineamientos y obligaciones en materia de protección de datos personales.

El Departamento de Datos Personales ejercerá las funciones y atribuciones previstas en el presente Manual y en las políticas internas aplicables, y asumirá, entre otras, las siguientes responsabilidades:

Compromiso integral con el cumplimiento de la Política General de Protección de Datos Personales (PGPDP).

Desarrollo, revisión y actualización de la PGPDP.

Verificación de la correcta implementación de la PGPDP.

Revisión periódica de la gestión de la PGPDP.

Capacitación y concientización del personal en materia de protección de datos personales.

Aprobación de procedimientos en los que se lleve a cabo el tratamiento de datos personales, incluyendo, de manera enunciativa mas no limitativa:

La administración y comunicación de avisos de privacidad;

La atención y gestión de solicitudes de los titulares de datos personales;

La recolección, uso y manejo de datos personales;

La gestión de quejas relacionadas con protección de datos personales;

La gestión de incidentes y vulneraciones de seguridad;

La contratación y supervisión de servicios externos que impliquen el tratamiento de datos personales.

Actuar como enlace con las áreas responsables de la gestión de riesgos y de la seguridad de la información dentro de Grünenthal.

Proporcionar asesoramiento en asuntos relacionados con autoridades competentes en materia de protección de datos personales, así como en proyectos que involucren el tratamiento, compartición o transferencia de datos personales.

Interpretar las excepciones y exenciones aplicables al tratamiento de datos personales conforme a la normatividad vigente.

Asegurar que Grünenthal cuente con información actualizada sobre cambios legislativos y criterios relevantes en materia de protección de datos personales.

Verificar que el Sistema de Gestión de Seguridad de Datos Personales (SGSDP) refleje los cambios en legislación, prácticas y tecnología, mediante una comunicación continua y proactiva de los riesgos a las partes interesadas.

Elaborar, presentar y gestionar las notificaciones que correspondan ante la autoridad competente y, en su caso, ante los titulares de datos personales, conforme a la normatividad aplicable.

Implementar, cuando resulte aplicable, las prácticas y lineamientos derivados de normativa sectorial obligatoria o de carácter orientativo en materia de protección de datos personales.

En atención a que Grünenthal cuenta con múltiples áreas, departamentos y sistemas que tratan datos personales, el Departamento de Datos Personales podrá determinar la conveniencia de establecer una red de enlaces o representantes internos en materia de protección de datos personales, quienes deberán:

Representar a áreas, procesos o sistemas identificados como relevantes por el tipo de tratamiento o por la naturaleza de los datos personales que gestionan,

Ayudar a los colaboradores con las responsabilidades diarias para el cumplimiento de la PGDP.

Responsabilidad de Empleados.

Todos los empleados y colaboradores de Grünenthal deberán conocer, asumir y cumplir la presente Política, así como la normativa interna vigente en materia de seguridad de la información y uso de los sistemas. En este sentido, estarán obligados a mantener el secreto profesional y la confidencialidad de la información a la que tengan acceso en el desarrollo de sus funciones, así como a comunicar, con carácter inmediato y conforme a los procedimientos establecidos, cualquier incidencia o problema de seguridad que sea detectado.

Asimismo, los empleados que contraten o gestionen servicios de terceros que impliquen el acceso o tratamiento de información deberán comprender los riesgos asociados a los procesos de externalización y asegurar una gestión adecuada y eficaz de dichos riesgos, de conformidad con las políticas internas aplicables.

El uso de los sistemas y servicios digitales por parte de los empleados, incluyendo de manera expresa el correo electrónico y los servicios de mensajería instantánea, deberá limitarse a fines lícitos y estrictamente profesionales, relacionados con las funciones propias del puesto de trabajo.

En consecuencia, dichos medios y sistemas no están destinados para uso personal y no podrán ser utilizados

para ninguna finalidad ilícita.

Responsabilidad en Relación con Terceros y Proveedores.

Los contratos celebrados con terceros que impliquen el uso o acceso de estos a la información, incluidos aquellos relativos a la prestación de servicios o a procesos de externalización, deberán incorporar requerimientos específicos de seguridad vinculados con la tecnología utilizada y con las actividades que dichos terceros lleven a cabo en el marco de la relación contractual.

En este sentido, dichos contratos deberán contemplar disposiciones que garanticen que los proveedores, su personal subcontratado o cualquier empresa externa que, de manera real o potencial, utilice o tenga acceso a la información de Grünenthal, ya sea a través de los sistemas o por cualquier otro medio, cuenten con las medidas de seguridad correspondientes, asuman la obligación de guardar la confidencialidad y cumplan con las demás obligaciones previstas en el Manual de Relaciones con Terceros de Grünenthal.

Departamento de Seguridad de la Información

El Departamento de Seguridad de la Información será presidido por un Oficial de Seguridad de la Información, quien ejercerá sus funciones de control de manera independiente y será responsable de implementar la presente Política y de supervisar su cumplimiento, así como el de todos los requerimientos derivados de las leyes, normas y buenas prácticas aplicables en materia de seguridad de la información.

El Oficial de Seguridad de la Información será responsable de:

Implementar una estrategia de seguridad de la información que asegure el cumplimiento de los principios básicos de la presente Política y que, en particular, contemple los siguientes aspectos:

Un acceso adecuado a la información, basado en el principio de mínimo privilegio y sujeto a la aprobación del responsable o dueño del activo de información.

Una segregación adecuada de roles y funciones dentro de los sistemas de información.

Una correcta configuración, administración y operación, desde el punto de vista de la seguridad, de la infraestructura, los servicios y el software utilizados en los distintos procesos de negocio, tanto dentro como fuera de las instalaciones de Grünenthal.

La correcta implementación de los requisitos de seguridad a lo largo del ciclo de vida de los sistemas de información que dan soporte a los procesos de Grünenthal.

Una protección adecuada de los sistemas y de la información que estos soportan frente a amenazas físicas o

ambientales, atendiendo a su nivel de criticidad, que permita identificar, evaluar, prevenir y responder a riesgos que puedan comprometer su seguridad.

Establecer y revisar los controles necesarios para asegurar el cumplimiento de la presente Política y de su normativa de desarrollo, incluyendo los mecanismos organizativos y tecnológicos requeridos para el monitoreo continuo de las actividades de acceso y uso de los sistemas, servicios e información gestionados por Grünenthal.

Prevenir, detectar y responder ante incidentes en materia de seguridad de la información, actuando conforme a lo establecido en el Plan de Respuesta ante Incidentes de Seguridad de Grünenthal.

Impulsar el desarrollo y actualización del marco normativo derivado de la presente Política.

Realizar actividades de formación y concientización en materia de seguridad de la información.

Establecer y promover un enfoque de mejora continua en los procesos de seguridad de la información.

Velar, de manera conjunta con el área de Cumplimiento, por el cumplimiento de la legislación vigente dentro del ámbito de las competencias que le atribuye la presente Política.

Plan de Trabajo para la Implementación de las Medidas de Seguridad Faltantes.

A partir de la identificación de las medidas y controles de seguridad faltantes según los resultados del Análisis de Brecha y el plan de tratamiento del riesgo se procederá a seleccionar los controles de seguridad faltantes y que requerirán ser implementados en Grünenthal.

El tratamiento del riesgo (mitigar o reducir el riesgo, retener el riesgo, evitar el riesgo y compartir el riesgo) se realizará de acuerdo con el siguiente esquema:

Grünenthal realizará la selección de las opciones de tratamiento del riesgo con base en el resultado de la valoración del riesgo, los costos estimados, y los beneficios esperados de implementar estas opciones.

Opciones de Tratamiento de riesgo consideradas.

Reducción de riesgo

Grünenthal considera las siguientes opciones de tratamiento de riesgo con la finalidad de seleccionar los controles apropiados y justificados para satisfacer los requerimientos especificados por la valoración del riesgo. Los controles podrán proporcionar uno o más de los siguientes tipos de protección:

Corrección

Eliminación

Prevención

Minimización del impacto

Disuasión

Recuperación

Monitoreo

Concienciación.

Para el tratamiento de los riesgos considerados en Grünenthal, se identificarán las soluciones que satisfagan sus requerimientos y que garanticen suficiente seguridad de los datos personales que se tratan de acuerdo con lo previsto en la Manual de Relaciones con Terceros.

La reducción del riesgo se podrá realizar mediante las siguientes acciones:

Acción

Descripción

Retención del riesgo

Se puede tomar la decisión de retener el riesgo sin considerar medidas adicionales si a través de la evaluación del riesgo se determina que no hay necesidad inmediata de implementar controles adicionales o que estos controles se pueden implementar posteriormente. Por ejemplo, el equipo de cómputo actual falla, pero se genera un respaldo de esa información al final del día, por lo que se decide retener ese riesgo durante un mes y esperar para cambiar el equipo de cómputo por uno nuevo.

Evitar el riesgo

Cuando el riesgo identificado es muy alto o los costos de tratamiento exceden a los beneficios, se debe tomar una decisión para evitar el riesgo, retirándose de las actividades actuales o cambiando las condiciones bajo las cuales operan dichas actividades. Por ejemplo, para un riesgo causado por la naturaleza podría ser más eficiente en costo mover físicamente el site de datos a una ubicación donde no exista el mismo riesgo o que se pueda mantener bajo control.

Compartir el Riesgo

Implica tomar la decisión de compartir el riesgo con un prestador de servicio que pueda gestionarlo, es decir, un tercero interviene para mitigar los posibles efectos de un riesgo, por ejemplo, al contratar un seguro o un proveedor que administre la seguridad de la organización. Cabe mencionar que cuando una organización comparte un riesgo no deja de ser responsable por la protección de los datos personales, además, es importante que se considere que involucrar a un nuevo actor en los procesos de la organización siempre representa un riesgo que debe ser analizado.

Aceptación de Riesgo Residual

Grünenthal asumirá y registrará formalmente el riesgo residual, describiendo cómo se tratarán los riesgos valorados para alcanzar los niveles de aceptación.

Comunicación de Riesgo.

La comunicación del riesgo se realizará considerando su naturaleza, forma, probabilidad, severidad, tratamiento y aceptación.

La comunicación efectiva con las personas involucradas será de carácter bidireccional, a fin de asegurar que

quienes participan en la implementación del SGSDP, así como las partes interesadas, comprendan los criterios en los que se fundamentan las decisiones adoptadas.

La comunicación del riesgo tendrá como objetivos:

Ofrecer garantías sobre la adecuada gestión del riesgo.

Recabar información relevante sobre el riesgo.

Compartir los resultados de la valoración del riesgo y el plan de tratamiento correspondiente.

Evitar o reducir vulneraciones de seguridad derivadas del desconocimiento entre los involucrados en el SGSDP.

Dar soporte a la toma de decisiones.

Generar nuevo conocimiento en materia de seguridad de la información.

Facilitar la coordinación entre los responsables del tratamiento de datos personales, los encargados y los terceros, respecto de los planes de respuesta ante una vulneración de seguridad.

Fomentar en los custodios y en las partes interesadas un sentido de responsabilidad respecto del riesgo.

Incrementar la concientización sobre el riesgo dentro de Grünenthal.

La comunicación del riesgo será una actividad continua y requerirá la participación de los custodios, propietarios y responsables de los activos de información de Grünenthal

Monitoreo y Revisión del SGSDP

En este apartado se establecerán los mecanismos para la evaluación y medición de los resultados de los, planes, procesos y procedimientos implementados, a fin de verificar que en el SGSDP se haya logrado la mejora esperada.

Revisión de Factores de Riesgo.

Se llevará a cabo un monitoreo y revisión continua del riesgo y de los factores asociados, incluyendo el valor de los activos, las amenazas, las vulnerabilidades, el impacto y la probabilidad de ocurrencia, con el objetivo de identificar oportunamente cualquier cambio en el contexto, el alcance y los objetivos de SGSDP de Grünenthal, y

mantener una visión actualizada del perfil de riesgo.

La revisión de los factores de riesgo permitirá el monitoreo, al menos, de los siguientes aspectos:

La incorporación de nuevos activos dentro del alcance de la gestión de riesgos.

Las modificaciones relevantes a los activos existentes, tales como cambios o migraciones tecnológicas.

La aparición de nuevas amenazas, internas o externas, que no hayan sido previamente valoradas.

La posibilidad de que vulnerabilidades nuevas o incrementadas sean explotadas por amenazas identificadas.

La reevaluación de vulnerabilidades previamente identificadas frente a amenazas nuevas o recurrentes.

Cambios en el impacto o en las consecuencias de amenazas, vulnerabilidades y riesgos, que puedan derivar en niveles de riesgo no aceptables.

La ocurrencia de incidentes y vulneraciones de seguridad.

Auditoria

En los sistemas de información y en las instalaciones en las que se lleve a cabo el tratamiento de datos personales, podrán realizarse auditorías periódicas, ya sean internas o externas, con el objeto de verificar el cumplimiento de la legislación aplicable a Grünenthal y el adecuado funcionamiento del SGSDP

Las auditorías se llevarán a cabo en intervalos previamente planificados con la finalidad de determinar, entre otros aspectos:

Si el SGSDP opera de conformidad con la Política de Gestión de Datos Personales y con los procedimientos establecidos, y

Si el SGSDP ha sido implementado y se mantiene de acuerdo con los requerimientos técnicos y tecnológicos aplicables.

Los resultados de las auditorías del SGSDP deberán ser comunicados a la Dirección, mediante los reportes correspondientes, en los que se detallen las desviaciones significativas respecto de la Política General de Datos Personales, incluyendo aquellas relacionadas con los procesos de seguridad que pudieran afectar su cumplimiento.

Los informes de auditoría elaborados por auditores internos y/o externos deberán pronunciarse sobre la adecuación de las medidas y controles existentes en Grünenthal a lo dispuesto en el presente documento, identificando, en su caso, las deficiencias detectadas y proponiendo las medidas correctivas o complementarias que resulten necesarias. Dichos informes deberán incluir la evidencia que sustente los dictámenes y recomendaciones formuladas.

El personal de seguridad revisará los informes de auditoría y, con base en sus conclusiones, las elevará a las instancias correspondientes, a fin de que Grünenthal adopte las medidas correctivas que resulten procedentes.

Incumplimiento.

Como resultado de una auditoría se establecerán observaciones sobre riesgos existentes para aplicar medidas preventivas, es decir, controles para que no ocurra una vulneración, así como observaciones sobre puntos que requieren medidas correctivas inmediatas.

El incumplimiento de las normas de seguridad en materia de protección de datos tendrá la consideración de falta laboral, cuya gravedad se determinará en el procedimiento que se siga de conformidad con las disposiciones vigentes; ello sin perjuicio de la responsabilidad administrativa, civil o penal, que, en su caso, sea directamente exigible al incumplidor de conformidad con la normatividad de aplicación en México.

Vulneraciones de Seguridad.

Grünenthal emprenderá las acciones que permitan el manejo de las vulneraciones de seguridad que puedan ocurrir de acuerdo con lo establecido en la Política de Atención a Vulneraciones de Seguridad de Datos Personales y los procedimientos que se describen en la misma.

Conforme a la Política de Atención a Vulneraciones de Seguridad de Datos Personales, las vulneraciones de seguridad se gestionarán de la siguiente forma:

Identificación de la vulneración. En caso de que se materialice un incidente de seguridad se identificará lo siguiente:

Los activos afectados junto con el personal a cargo.

Los titulares afectados.

Partes interesadas que requieran estar informadas y/o puedan tomar parte en la toma de decisiones para mitigar las consecuencias de la vulneración.

Notificación de la vulneración. Grünenthal analizará los riesgos que puede suponer la vulneración para los derechos patrimoniales y morales de los Titulares, y en caso de considerar que existe una afectación significativa a la misma, activará el protocolo de notificación de vulneración. Una vez analizada la vulneración y que se ha determinado la obligatoriedad de su notificación, ésta se comunicará a los titulares de los datos personales para que puedan tomar medidas que mitiguen o eviten una posible afectación de acuerdo con el procedimiento establecido en la Política de Atención a Vulneraciones de Seguridad de Datos Personales.

Remediación del incidente. Una vez identificada la vulneración y después de haber realizado la respectiva notificación, se profundizará en el análisis de las causas para establecer medidas correctivas, las cuales incluirán medidas inmediatas para reducir los efectos de la vulneración de acuerdo con el procedimiento establecido en los Anexos de la Política de Atención a Vulneraciones de Seguridad de Datos Personales.

Las revisiones, auditorías y los tratamientos de una vulneración a la seguridad al SGSDP se documentarán, incluyendo un resumen de los hallazgos y los planes para aplicar medidas preventivas y correctivas con objeto de demostrar la diligencia debida en la adopción de las acciones necesarias para evitar o mitigar una vulneración a la seguridad de los datos personales.

Mejora del SGSDP.

El monitoreo de los factores de riesgo, así como los resultados de las auditorías proporcionan información para demostrar la eficacia del SGSDP, pero también presentan las áreas de oportunidad donde éste puede ser mejorado. Los puntos de mejora del SGSDP pueden corresponder a dos tipos:

a) Acciones correctivas. Son las acciones encaminadas a eliminar las causas de fallas o incidentes ocurridos en el SGSDP, con objeto de prevenir que vuelvan a ocurrir, dichas acciones deben ser proporcionales a la gravedad del incidente.

Las acciones correctivas deben atenderse considerando:

El análisis y revisión de la falla o incidente;

Determinar las causas que dieron origen a la falla o incidente;

Evaluar las acciones necesarias para evitar que la falla o incidente vuelva a ocurrir;

Determinar e implementar las acciones necesarias;

Registrar los resultados de las acciones tomadas; Revisar la eficacia de las acciones correctivas tomadas.

b) Acciones preventivas. Son las acciones encaminadas a eliminar las causas de fallas o incidentes posibles en el SGSDP, dichas acciones deben ser proporcionales a las amenazas potenciales.

Las acciones preventivas deben atenderse considerando:

El análisis y revisión de la amenaza;

Determinar las fallas o incidentes que podría desencadenarse con una amenaza;

Evaluar las acciones necesarias para evitar que la falla o incidente ocurra;

Determinar e implementar las acciones necesarias;

Registrar los resultados de las acciones tomadas;

Revisar la eficacia de las acciones preventivas tomadas.

La implementación de las acciones preventivas o correctivas se establecerá en un periodo inmediato a la detección y análisis del punto de mejora en función de la importancia de la mejora y los recursos disponibles.

La eficacia de las acciones preventivas y correctivas se evaluará considerando la reducción de los niveles de riesgo en los resultados del monitoreo a los SGSDP.

De acuerdo con las acciones correctivas y preventivas, así como del resultado del monitoreo del riesgo, se establecerán mejoras en los programas de capacitación

Capacitación.

Grünenthal se encuentra altamente comprometida con la realización y promoción de cursos de sensibilización y capacitación sobre protección de datos personales en soportes físicos y soportes electrónicos para los empleados que tienen funciones asignadas para interactuar con datos personales al interior de la empresa y para los proveedores externos, que interactúan con uno o más sistemas de datos personales (quienes también deben asegurar la protección de datos personales).

El Programa de Capacitación de Grünenthal, considera los siguientes factores:

Concienciación: programas a corto plazo para la difusión en general de la protección de datos personales en Grünenthal;

Entrenamiento: programas a mediano plazo que tienen por objetivo capacitar al personal de manera específica respecto a sus funciones y responsabilidad en el tratamiento y seguridad de los datos personales y;

Educación: programa general a largo plazo que tiene por objetivo incluir la seguridad en el tratamiento de los datos personales dentro de la cultura de Grünenthal.

Se debe realizar una detección de necesidades para identificar el nivel y tipo de capacitación necesaria para el personal, de acuerdo con las responsabilidades asignadas y tomando en cuenta su perfil de puesto, especialmente de aquéllos involucrados en el tratamiento de datos personales.

Estos programas de capacitación a su vez consideran los siguientes elementos:

Requerimientos y actualizaciones al contexto del SGSDP, considerando principalmente;

La administración y comunicación de noticias de privacidad;

El manejo de solicitudes y quejas de los titulares;

La recolección y manipulación de datos personales;

La gestión de incidentes y vulneraciones de seguridad, y

La gestión de seguridad con terceros.

La legislación en protección de datos personales y mejores prácticas relacionadas al tratamiento de datos aplicables a Grünenthal;

Las consecuencias del incumplimiento de los requerimientos legales o requisitos organizacionales;

Las herramientas tecnológicas relacionadas o utilizadas para el tratamiento de datos personales y para la implementación de medidas de seguridad, y

Instructores expertos en la materia.

El alcance de los cursos de sensibilización y capacitación, su periodicidad y contenido, se irá actualizando y detallando por el área de Recursos Humanos y de Capacitación de Grünenthal.

Asimismo, para que el SGSDP pueda garantizar de manera adecuada sus niveles de seguridad es necesario que todo su personal cuente con la concienciación y capacitación suficiente para evitar que existan riesgos de una violación o amenaza a la información por este frente.

Los Programa de Concienciación y Capacitación de Grünenthal contienen los siguientes pasos:

Identifica el alcance del programa, metas y objetivos. El alcance del programa de capacitación –según sea el caso– contempla los distintos niveles de usuarios que interactúan con el sistema.

Identifica al Personal que Imparte la Capacitación. El personal que imparte la capacitación y difunde la concienciación de la seguridad tiene el conocimiento necesario en materia de seguridad, principios y técnicas informáticas.

Identifica el Público. Los programas de capacitaciones distinguen entre los diferentes puestos y funciones, ya que no todos necesitan el mismo nivel de capacitación. Por lo que, las capacitaciones van enfocadas en relación con los requisitos de cada área.

Motivación al Personal. Para poder lograr una implementación exitosa del sistema se cuenta con el apoyo tanto de las direcciones como de los empleados, con la finalidad de que estos se vean motivados a actuar de manera acorde al sistema y sus medidas de seguridad.

Administración del Programa. Algunos de los elementos que considera Grünenthal para la administración del programa de capacitación son: la selección de métodos apropiados de capacitación, temas a tratar, materiales a usarse y técnicas de presentación utilizadas en la capacitación.

Duración de la capacitación. La capacitación se mantiene vigente durante el mayor tiempo posible. Sin embargo, se considera que un determinado programa de capacitación se puede volver obsoleto al momento de implementar nuevas tecnologías.

Evaluación del programa. Se evaluará la eficiencia y eficacia de la capacitación, mediante la aplicación de exámenes teóricos y prácticos que permitan indicar el grado de conocimiento y/o entendimiento de la capacitación proporcionada o difusión realizada. Se establecerán criterios de evaluación que determinen el nivel de competencia aceptado por Grünenthal, y mantener un registro de los programas seguidos por cada empleado, así como de sus habilidades, experiencia y calificaciones de conformidad con el Programa de Capacitación en

materia de Seguridad y Datos Personales definido por Grünenthal.

Referencias

Procedimiento operativo estándar sobre la gestión de incidentes de seguridad.

Índice histórico

n/a

Revisión/n.º de documento

Descripción de los cambios

01

Nuevo documento